

信息安全应急响应预案

第一章 总则

文档编号：SEC-IR-2026-005。版本：V3.4。发布日期：2026年3月30日。批准人：安全委员会。密级：秘密。本预案适用于公司全部信息系统发生或可能发生信息安全事件时的应急响应工作。

第二章 事件分级

一、分级标准

一级（特别重大）：核心业务系统全面瘫痪超过四小时，或泄露客户敏感数据超过十万条，或造成直接经济损失超过五百万元。二级（重大）：核心业务部分中断超过一小时，或内部数据泄露超过一万条，或数据被篡改影响对外服务。三级（较大）：单一系统故障、发现高危漏洞被利用迹象、少量内部数据异常泄露。四级（一般）：单点病毒感染、钓鱼邮件被拦截、扫描探测行为。

二、响应时限要求

一级事件：十分钟内值班安全工程师确认，三十分钟内成立应急指挥部，一小时内向总经理与安全委员会书面报告。二级事件：三十分钟内确认，两小时内报告安全负责人。三级事件：两小时内确认，当日内处置完毕并记录。四级事件：值班内处置，工单跟踪闭环。

第三章 应急组织

应急指挥部由安全负责人任总指挥，成员包括安全组、运维组、研发中心代表、法务合规与公关代表。下设四个职能小组：一、监测研判组：负责事件确认、影响评估与取证固证；二、处置组：负责抑制、根除与恢复实施；三、沟通组：负责内部通报与对外口径管理；四、法务组：负责监管报送与证据链合规审查。

第四章 标准响应流程

一、准备阶段

日常准备包括：资产台账季度更新（覆盖全部域名、IP、系统与责任人）、应急预案年度演练不少于两次、备份有效性按《数据库备份与恢复指南》抽检、堡垒机与日志平台全量覆盖、蜜罐与入侵检测规则月度评审。

二、检测与研判

接报或告警后，值班工程师十分钟内完成初步研判：确认事件真实性、影响系统范围、初步定级。研判证据（流量截图、日志片段）立即固化到只读存储。定级有争议时按就高原则先响应后调整。

三、抑制阶段

抑制措施按影响从小到大依次考虑：封禁攻击源 IP、下线受影响服务、切断异常外联、关闭相关端口、账号强制下线与改密、必要时断开互联网出口。执行任何抑制操作前须在处置群同步并留下操作记录，重大动作需总指挥确认。

四、根除与恢复

根除阶段须找到入侵入口并彻底清除：清理后门账户与定时任务、重装被控主机、更换全部可能泄露的凭证与密钥。恢复按「备份恢复、灰度验证、全量切流」三步执行，恢复后连续观察四十八小时。恢复期间业务降级方案由处置组同步准备。

五、复盘阶段

一二级事件恢复后五个工作日内召开复盘会，产出事件报告：完整时间线、根因分析、损失评估、责任认定、改进措施（落实到人）。改进措施纳入安全组季度任务跟踪，完成情况在安全委员会汇报。

第五章 专项处置预案

一、勒索软件专项

发现勒索加密行为立即断网不断电（保留内存证据），隔离同网段其他主机，禁止支付赎金；评估备份可用性后按备份体系重建。全部密钥类凭证（数据库密码、API Key、SSH 私钥）视为已泄露并强制轮换。

二、数据泄露专项

确认泄露范围后两小时内完成：泄露数据类型与数量评估、泄露通道定位、阻断。涉及客户个人信息超过一万条的，法务组按监管要求评估上报义务，对外口径由公关统一管理，任何个人不得私自回应。

三、DDoS 攻击专项

联系运营商启动流量清洗，切换高防 IP，非核心服务临时下线保障核心链路带宽；攻击结束后保留完整攻击流量样本用于加固规则。单次攻击峰值超过 10Gbps 自动升级为二级事件。

四、内部违规专项

员工违规导出数据、越权访问等内部事件由安全组与人力资源部联合调查，涉及劳动合同解除或司法移送的由法务组主导。调查期间相关人员账号暂停但数据保留。

第六章 上报矩阵

一级事件上报链：值班工程师、安全负责人、总经理、监管机构（如适用）。二级事件上报链：值班工程师、安全负责人。三级及以下事件在安全周报中汇总上报。任何级别事件涉及客户合同约定的，由客户成功部按合同约定时间窗口同步客户。

第七章 演练与维护

每半年至少一次红蓝对抗演练，每年至少一次全要素实战演练（含勒索与数据泄露场景）。演练后十个工作日内更新预案。预案联系人通讯录每月校对一次，人员变动时即时更新。本预案由安全组负责解释。